

Tiny Second-hand Shopping Platform 개발 보고서

시큐어 코딩 과제 제출용 문서

작성일	2026-07-24
프로젝트명	Tiny Second-hand Shopping Platform
기술 스택	Node.js 24, Express, Socket.IO, node:sqlite, EJS
저장소 상태	로컬 Git 저장소 준비 완료, GitHub public push 대기

1. 요구사항 분석

과제 PDF의 최소 요구사항을 기준으로 회원가입/로그인, 상품 등록 및 조회, 사용자 간 소통, 악성 유저 및 상품 차단, 사용자 간 송금, 관리자 기능을 핵심 범위로 정의했다.

비기능 요구사항은 보안, 가용성, 유지보수성으로 정리했다. 특히 보안 과제 성격상 인증, 입력 검증, 세션 관리, 권한 검증, SQL 인젝션 및 XSS 방어를 우선순위로 두었다.

- 회원가입 및 로그인 구현
- 상품 등록, 조회, 상세보기, 검색 구현
- 전체 채팅과 1:1 채팅 구현
- 신고 누적 기반 자동 차단과 관리자 제재 구현
- 사용자 간 송금 기능 구현
- 관리자 대시보드 구현

2. 시스템 설계

서버는 Express 기반으로 구성했고, 데이터 저장은 Node.js 24 내장 SQLite 모듈인 node:sqlite를 사용했다. 화면은 EJS 서버 렌더링으로 구성하여 구조를 단순하게 유지했다.

실시간 소통 기능은 Socket.IO로 구현했으며, 전체 채팅과 사용자별 1:1 채팅 채널을 분리했다. 권한은 일반 사용자와 관리자로 나누고, 관리자만 전체 플랫폼 상태를 변경할 수 있도록 설계했다.

- users: 계정, 역할, 상태, 잔액 관리
- products: 상품 정보와 상태 관리
- reports: 신고 대상, 신고자, 사유 관리
- global_messages / direct_messages: 채팅 기록 관리

- transfers: 송금 이력 관리

3. 구현 내용

사용자 기능으로 회원가입, 로그인, 로그아웃, 마이페이지, 비밀번호 변경을 구현했다. 상품 기능으로는 등록, 목록, 상세보기, 검색, 내 상품 상태 관리 기능을 구현했다.

소통 기능으로 전체 채팅과 1:1 실시간 채팅을 구현했고, 송금 기능으로 사용자 간 금액 이동 및 메모 저장을 지원했다. 관리자 기능으로 사용자 상태 변경, 상품 상태 변경, 신고 현황 조회를 제공한다.

- 회원가입 / 로그인 / 로그아웃 / 프로필 수정
- 상품 등록 / 상품 조회 / 상품 검색 / 상품 상태 관리
- 전체 채팅 / 1:1 채팅
- 사용자 간 송금 및 거래 메모
- 신고 접수 / 자동 차단 / 관리자 제재

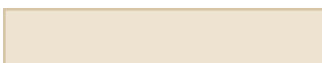
4. 보안 약점 확인 및 개선

초기 구조에서 가장 먼저 고려한 약점은 평문 비밀번호 저장, CSRF, SQL 인젝션, XSS, 권한 우회, 중복 신고, 업로드 취약점이었다. 이에 따라 설계 초기부터 보안 제어를 기능 요구사항과 함께 반영했다.

항목	위험	변경 내용
비밀번호 저장	계정 탈취	bcrypt 해시 저장
인증 요청	브루트포스	rate limit 적용
상태 변경	CSRF	CSRF 토큰 검증
입력 처리	XSS / 이상 입력	Zod 검증 + EJS escape
SQL 처리	SQL 인젝션	prepared statement 사용
이미지 처리	악성 업로드	URL 기반 입력만 허용
권한 제어	인가 우회	인증/관리자/소유자 검증
신고 기능	중복 악용	UNIQUE 제약과 예외 처리

5. 체크리스트 및 테스트

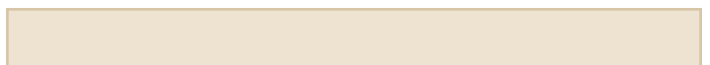
기능 체크리스트와 보안 체크리스트를 문서화했고, 자동 테스트와 스모크 테스트를 수행했다. 자동 테스트는 회원가입/로그인, 신고 임계치 기반 상품 차단, 송금 잔액 이동을 검증하도록 작성했다.



검증 항목



방법



결과

회원가입/로그인



node:test + supertest



PASS



신고 임계치 차단



store 단위 자동 테스트

PASS

송금 잔액 이동

store 단위 자동 테스트

PASS

/login 페이지 응답

실행 후 스모크 테스트

PASS

전역 채팅 / 1:1 채팅

구현 완료, 수동 검증 대
상

READY

관리자 상태 변경

구현 완료, 수동 검증 대
상

READY

6. AI 활용 내역

이번 과제에서는 AI 도구를 적극적으로 활용했다. 요구사항 해석, 기능 분해, 보안 점검 항목 도출, 테스트 시나리오 구성, 문서 구조화, 초기 코드 구조 생성과 하드닝 과정에서 AI의 도움을 받았다.

다만 AI가 생성한 결과는 그대로 사용하지 않고, 보안 요구사항 누락 여부와 실제 동작 여부를 기준으로 다시 점검했다. 특히 인증, 권한, 입력 검증, 세션, 신고 악용 가능성은 사람이 직접 검토했다.

7. 유지보수 계획

- 이미지 업로드가 필요할 경우 전용 스토리지와 파일 검증 체계 추가
- 채팅 신고 기능과 관리자 감사 로그 추가
- 배포 시 세션 저장소를 Redis 또는 DB 기반으로 전환
- 관리자 작업 이력 추적 기능 추가

8. GitHub 공개 업로드 메모

로컬 Git 저장소는 준비되었고 README도 작성했다. 다만 이 환경에는 GitHub CLI가 설치되어 있지 않고 사용자 계정 인증 정보도 확인되지 않아, 원격 저장소 생성과 public push는 아직 수행하지 않았다.

원격 저장소 생성 후에는 `git remote add origin <repo-url>` 및 `git push -u origin main` 단계로 공개 업로드를 진행하면 된다.